

Cybersecurity Breach -- Post-Incident Report

October 2024 Security Incident | Classification: CONFIDENTIAL
Prepared by: Rafael Gomes (CTO) + Sofia Chen (VP Engineering)
Distribution: Board of Directors + Legal + DPO

Incident Summary

On September 28, 2024 at 03:47 UTC, NexaCore's automated monitoring system detected anomalous outbound traffic from the authentication microservice. Investigation confirmed unauthorized API access via a compromised JWT signing key stored in plaintext in AWS SSM Parameter Store. The attacker accessed read-only audit log data for 340 enterprise accounts.

Full service was restored October 2, 2024 at 14:00 UTC -- 78 hours after detection.

PLATFORM AVAILABILITY: 91.2% over the 7-day incident window (SLA: 99.5%)
DATA EXFILTRATION: No evidence found. Audit logs accessed (account IDs + timestamps only).

Timeline of Events

Event	
03:47 UTC	Alert: anomalous outbound traffic f
04:22 UTC	Confirmed unauthorized API access
06:00 UTC	Key rotated. 2,400 active session
08:30 UTC	Customers notified via email +
09:15 UTC	Forensics: attacker accessed read-onl
14:00 UTC	33 notification filed to Dutch D
14:00 UTC	Restoration. Post-mortem initiat
	IMDSv2 enforced across all EC2 instances flee
	SSM Parameter Store secrets migrated to S
	Corp Vault enterprise contract signed. I

Root Cause Analysis

TECHNICAL ROOT CAUSE: JWT signing key stored as plaintext in AWS SSM Parameter Store (should have been SecureString). Attacker accessed it via a compromised EC2 instance metadata service (IMDSv1 vulnerability).

CONTRIBUTING PROCESS FAILURES:

- 1. Secret rotation policy did not cover infrastructure keys (only API keys)
- 2. IMDSv2 enforcement was optional, not mandatory, fleet-wide

- 3. Outbound traffic anomaly detection threshold set 10x too high
- 4. Incident response runbook for auth service compromise was 18 months out of date
- 5. No separation of duties between secret creation and access (single IAM role)

Financial Impact

Amount (USD)	
\$84,200	Credits to Enterprise customers (10% x af
\$18,400	ring overtime (incident response, 78 h
\$42,000	forensics (Mandiant, 5 days)
\$135,000	op Vault license + implementation
\$48,000	penetration testing (NCC Group, Q1 2
\$240,000	l security engineer hire (annual)
\$60,000	(churn triggered by breach, estimate
\$951,600	DIRECT + INDIRECT COST

Remediation Status

Completed	
Done	2024 Mitigation (all environments)
Done	2024 Net-wide enforcement
Done	2024 Meter Store encryption audit
Done	2024 Password reset + MFA enforcement
Not Done	2024 Patch deployment (94%)
Not Done	2024 Patch refresh (60% complete)
Not Done	2025 Sup penetration test
Not Done	2025 Type II recertification